



Paso de preparación del marco de gestión de riesgos (RMF) del NIST

La adición del paso Preparar es una de las actualizaciones clave del Marco de gestión de riesgos (NIST Special Publication 800-37, Revisión 2 [SP 800-37r2]). El paso Preparar se incorporó para lograr procesos de gestión de riesgos de seguridad y privacidad más efectivos, eficientes y rentables. Las tareas en el paso Preparar respaldan directamente los pasos posteriores de RMF y se derivan en gran medida de la orientación en otras publicaciones del NIST o son requeridas por la política de la Oficina de Administración y Presupuesto (OMB) (o ambas). Por lo tanto, es posible que las organizaciones ya hayan implementado muchas de las tareas del paso Preparar como parte de la gestión de riesgos en toda la organización. El paso Preparar pretende reducir la complejidad a medida que las organizaciones implementan el marco de gestión de riesgos, promover los objetivos de modernización de TI, conservar los recursos de seguridad y privacidad, priorizar las actividades de seguridad para enfocar las estrategias de protección en los activos y sistemas más críticos y promover la protección de la privacidad de las personas.



pasos restantes de RMF. Sin una preparación adecuada para la gestión de riesgos a nivel organizativo y de sistema, las actividades de seguridad y privacidad pueden volverse demasiado costosas, demandar demasiados profesionales de seguridad y privacidad capacitados y producir soluciones ineficaces.

Contenido

Preguntas frecuentes generales sobre el paso de preparación	2
1. ¿Cómo impacta el paso Preparar la implementación actual del Marco de Gestión de Riesgos de mi organización?	2
2. ¿Qué es el paso Preparar?	3
3. ¿Cuáles son algunos de los objetivos y beneficios del paso Preparar?	3
4. ¿Cuáles son los resultados del paso Preparar?	3
5. ¿Quién es responsable de realizar las tareas del paso Preparar?	3
6. ¿Por qué el paso Preparar está separado en nivel organizacional y nivel de sistema?.....	3
7. ¿El paso Preparar requiere actividades nuevas o adicionales para los programas de seguridad y privacidad?	3
8. ¿Cómo se alinea el paso Preparar con el marco de ciberseguridad (CSF) del NIST?	4
9. ¿Cómo se alinea el paso Preparar con el marco de privacidad del NIST?	4
10. ¿Hay otros recursos disponibles para ayudar a mi organización a implementar el paso Preparar?	5
11. ¿Por qué algunas tareas del paso Preparar son opcionales?	5
12. ¿Dónde encaja el paso Preparar en los pasos existentes del RMF?	5
13. ¿Cuándo se consideran los requisitos de seguridad y privacidad dentro del ciclo de vida del desarrollo del sistema?	5
Preguntas frecuentes sobre los fundamentos de los pasos de preparación	6
14. ¿Qué es una estrategia de gestión de riesgos y por qué es necesaria?	6
15. ¿Qué es una evaluación de riesgos?	6

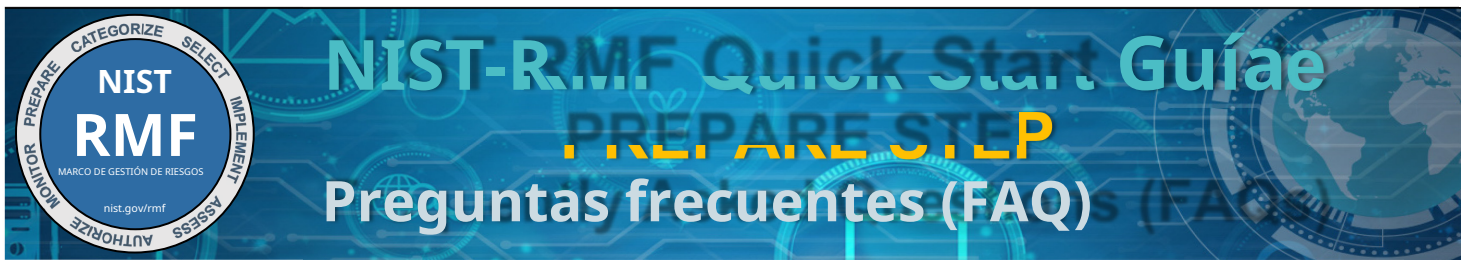


16. ¿Qué es un perfil de Cybersecurity Framework o Privacy Framework?.....	6
17. ¿Qué es un control común?	7
18. ¿Cómo se determinan los controles comunes para la organización?	7
19. ¿Quién debe definir los controles comunes?	7
20. ¿Qué es una arquitectura empresarial?	8
21. ¿Cuál es la diferencia entre los requisitos de seguridad y privacidad y los controles de seguridad y privacidad?	8
22. ¿Qué es un límite de autorización?	8
23. ¿Es el límite de la autorización lo mismo que el límite del sistema?	8
24. ¿Cuándo se debe establecer el límite de autorización?	9
25. ¿Quién es responsable de establecer el límite de autorización?	9
26. ¿Cómo se establece el límite de autorización?	9
27. ¿Cuáles son los distintos tipos de información que procesan los sistemas de gobierno?.....	10
Asistencia organizativa para las preguntas frecuentes sobre el paso de preparación	11
28. ¿Cómo establecen las organizaciones tipos de información basados en la misión?	11
29. ¿Cuáles son las funciones y responsabilidades clave de la organización en el paso Preparar?	11
30. ¿Qué es una línea de base de control adaptada a la organización?	11
31. ¿Cuál es el origen de las nuevas tareas en el paso Preparar - Nivel organizacional?	12
Preguntas frecuentes sobre la aplicación específica del sistema del paso de preparación	12
32. ¿Por qué se agregó la tarea de límites de autorización?.....	12
33. ¿Qué es el ciclo de vida de la información?	12
34. ¿Qué es el registro del sistema?	12
35. ¿Cuál es el origen de las nuevas tareas en el paso Preparar - Nivel del sistema?	12
Referencias.....	13

Preguntas frecuentes sobre el paso de preparación general

1. ¿Cómo impacta el paso Preparar la implementación actual del Marco de Gestión de Riesgos de mi organización?

El paso Preparar no pretende requerir actividades nuevas o adicionales para los programas de seguridad y privacidad. Más bien, enfatiza la importancia de tener un gobierno integral en toda la organización y los recursos apropiados para permitir la ejecución de procesos de gestión de riesgos consistentes y rentables en toda la organización. La mayoría de las tareas incluidas en el paso Preparar se derivan de la guía existente del NIST y/o los requisitos de la política de la OMB y son actividades fundamentales que respaldan la implementación de los pasos posteriores del Marco de gestión de riesgos. [\[Volver a la tabla de contenidos\]](#)



2. ¿Qué es el paso Preparar?

El propósito del paso Preparar es llevar a cabo tareas esenciales de gestión de riesgos en la organización, la misión y el proceso comercial, y los niveles del sistema para establecer el contexto y ayudar a preparar a la organización para gestionar sus riesgos de seguridad y privacidad utilizando el marco de gestión de riesgos. Las tareas del paso Preparar se completan antes del paso Categorizar y son compatibles con todos los pasos y tareas posteriores del Marco de gestión de riesgos. En última instancia, la intención del paso Preparar es proporcionar la información y los recursos necesarios para administrar con éxito la seguridad de la información y el riesgo de privacidad para la organización y sus misiones a partir de la operación y el uso de los sistemas. [\[Volver a la tabla de contenidos\]](#)

3. ¿Cuáles son algunos de los objetivos y beneficios del paso Preparar?

Los objetivos y beneficios del paso Preparar incluyen:

- Facilitar una mejor comunicación entre los líderes sénior y los ejecutivos a nivel de la organización y la misión y los procesos comerciales y los propietarios del sistema.
- Facilitar la identificación de controles comunes en toda la organización y el desarrollo de líneas de base de control adaptadas a la organización, lo que reduce la carga de trabajo de los propietarios de sistemas individuales y el costo del desarrollo del sistema y la protección de activos.
- Reducir la complejidad de la tecnología de la información y la infraestructura de tecnología de operaciones utilizando conceptos y modelos de arquitectura empresarial para consolidar, optimizar y estandarizar sistemas, aplicaciones y servicios organizacionales
- Identificar, priorizar y concentrar los recursos en los activos de alto valor de la organización y los sistemas de alto impacto que requieren mayores niveles de protección y tomar medidas acordes con el riesgo de dichos activos. [\[Volver a la tabla de contenidos\]](#)

4. ¿Cuáles son los resultados del paso Preparar?

Un resultado es el resultado de una tarea específica identificada en NIST SP 800-37 [\[SP 800-37r2\]](#). Para obtener una lista de los resultados de cada tarea en el paso Preparar, consulte la Tabla 1: *Preparar tareas y resultados: nivel de organización* y Tabla 2: *Preparar Tareas y Resultados – Nivel de Sistema*. [\[Volver a la tabla de contenidos\]](#)

5. ¿Quién es responsable de realizar las tareas del paso Preparar?

Cada tarea en el paso Preparar identifica la(s) función(es) principal(es) responsable(s) de garantizar la implementación y finalización de la tarea, así como las funciones de apoyo para ayudar o brindar orientación o experiencia para la implementación de la tarea. Referirse a *Cruce de roles y responsabilidades de RMF* tabla de funciones y responsabilidades asociadas con las tareas del paso Preparar. Para obtener una descripción de los roles y sus responsabilidades asociadas, consulte el Apéndice D: *Funciones y responsabilidades*. [\[Volver a la tabla de contenidos\]](#)

6. ¿Por qué el paso Preparar se separa en nivel organizacional y nivel de sistema?

Las actividades preparatorias se agrupan en preparación a nivel de organización y preparación a nivel de sistema para facilitar su uso y aclarar las funciones y responsabilidades apropiadas. [\[Volver a la tabla de contenidos\]](#)

7. ¿El paso Preparar requiere actividades nuevas o adicionales para los programas de seguridad y privacidad?

No, las tareas del paso Preparar se basan en los requisitos de la política OMB existentes y en la orientación relacionada con la gestión de riesgos de otras publicaciones del NIST, incluido el NIST SP 800-30 [\[SP 800-30\]](#), NIST SP 800-39 [\[SP 800-39\]](#), NIST SP 800-137 [\[SP 800-137\]](#), NIST SP 800-160 [\[SP 800-160\]](#) y NISTIR 8062 [\[IR 8062\]](#). Cada tarea del paso Preparar incluye referencias específicas al origen de la tarea y la publicación de respaldo. [\[Volver a la tabla de contenidos\]](#)



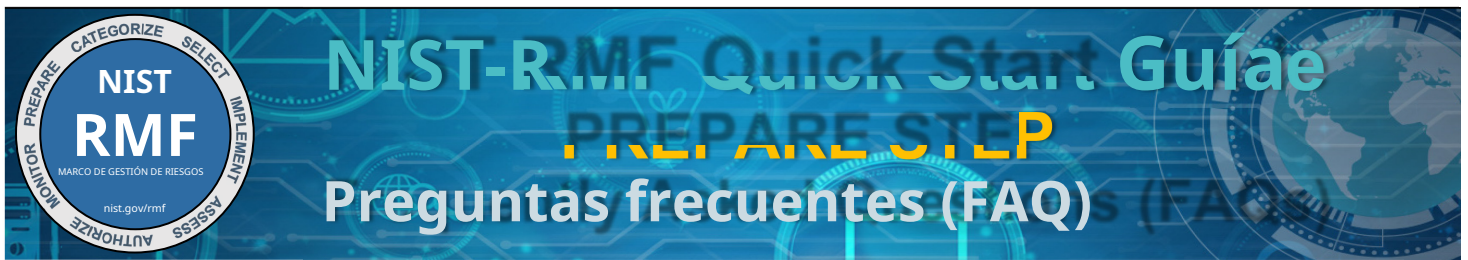
8. ¿Cómo se alinea el paso Preparar con el marco de ciberseguridad (CSF) del NIST?

Para garantizar una implementación eficaz y eficiente del marco de seguridad cibernética, se han actualizado varias áreas clave dentro del RMF. Cada tarea en el RMF incluye referencias a las secciones aplicables del marco de seguridad cibernética. Por ejemplo, Preparar RMF: paso Nivel de organización, Tarea P-2, *Estrategia de gestión de riesgos*, se alinea con el Núcleo del Marco de Seguridad Cibernética [Identificar Función]; Preparación de RMF: paso de nivel de organización, tarea P-4, *Líneas base de control adaptadas a la organización y perfiles del marco de ciberseguridad*, se alinea con el constructo de *Perfiles del marco de ciberseguridad*. [[Volver a la tabla de contenidos](#)]

9. ¿Cómo se alinea el paso Preparar con el marco de privacidad del NIST?

El *Marco de privacidad de NIST: una herramienta para mejorar la privacidad a través de la gestión de riesgos empresariales* [PF del NIST] proporciona un método simple de "listo, listo, listo" para establecer o mejorar un programa de privacidad. El objetivo de su "ListoLa fase" puede compararse con la RMF *Preparar* para ayudar a las organizaciones a establecer las bases para tareas posteriores y Categorías/Subcategorías para respaldar sus procesos de gestión de riesgos. Algunas de las tareas en el paso Preparar admiten ciertos resultados en el marco de privacidad de NIST y viceversa. La siguiente tabla proporciona una asignación entre las tareas del paso Preparar y las Categorías/Subcategorías del marco de privacidad. Para ver la asignación completa de SP 800-37, revisión 2, al marco de privacidad, visite el repositorio de recursos del marco de privacidad en <https://www.nist.gov/privacy-framework/resource-repository>. [[Volver a la tabla de contenidos](#)]

NIST SP 800-37 Preparar tareas de paso	Categorías/subcategorías del marco de privacidad del NIST
Tarea P-1 , Funciones de gestión de riesgos	Políticas, procesos y procedimientos de gobernanza (GV.PO-P3y GV.PO-P4) Concienciación y Formación (GV.AT-P2yGV.AT-P3) Políticas, procesos y procedimientos de comunicación (CM.PO-P2)
Tarea P-2 , Estrategia de Gestión de Riesgos	Estrategia de gestión de riesgos (GV.RM-P) Gestión de riesgos del ecosistema de procesamiento de datos (ID.DE-P1)
Tarea P-3 , Evaluación de Riesgos – Organización	Evaluación de riesgos (ID.RA-P) Seguimiento y revisión (GV.MT-P1)
Tarea P-4 (opcional) , líneas de base de control adaptadas a la organización y perfiles del marco de ciberseguridad	Políticas, procesos y procedimientos de gobernanza (GV.PO-P5)
Tarea P-5 , Identificación de control común	(ninguno)
Tarea P-6 (Opcional), Priorización del nivel de impacto	(ninguno)
Tarea P-7 , Estrategia de Monitoreo Continuo – Organización	(ninguno)
Tarea P-8 , Misión o Enfoque de Negocio	Ambiente de negocios (ID.BE-P2yID.BE-P3)
Tarea P-9 , Actores del Sistema	Inventario y Mapeo (ID.IM-P2) Ambiente de negocios (ID.BE-P1) Evaluación de riesgos (ID.RA-P1yID.RA-P2)
Tarea P-10 , Identificación de activos	Inventario y Mapeo (ID.IM-P1yID.IM-P2)
Tarea P-11 , límite de autorización	(ninguno)
Tarea P-12 , Tipos de información	Inventario y Mapeo (ID.IM-P6)
Tarea P-13 , Ciclo de vida de la información	Inventario y Mapeo (ID.IM-P4, ID.IM-P5, yID.IM-P8) Políticas, Procesos y Procedimientos de Tratamiento de Datos (GV.PO-P5y GV.PO-P6)
Tarea P-14 , Evaluación de Riesgos – Sistema	Evaluación de riesgos (ID.RA-P4yID.RA-P5) Seguimiento y revisión (GV.MT-P1)
Tarea P-15 , Definición de requisitos	Políticas, procesos y procedimientos de gobernanza (GV.PO-P5y GV.PO-P6)
Tarea P-16 , Arquitectura empresarial	Inventario y Mapeo (ID.IM-P7) Políticas, procesos y procedimientos de gobernanza (GV.PO-P6)
Tarea P-17 , Requerimientos Asignación	(ninguno)
Tarea P-18 , Registro del sistema	(ninguno)



10. ¿Hay otros recursos disponibles para ayudar a mi organización a implementar el paso Preparar?

Cada tarea en el paso Preparar incluye referencias a publicaciones de apoyo relevantes que brindan orientación adicional para completar la tarea. Consulte el sitio web del proyecto de implementación de NIST FISMA (<https://nist.gov/rmf>) para recursos adicionales. [\[Volver a la tabla de contenidos\]](#)

11. ¿Por qué algunas tareas del paso Preparar son opcionales?

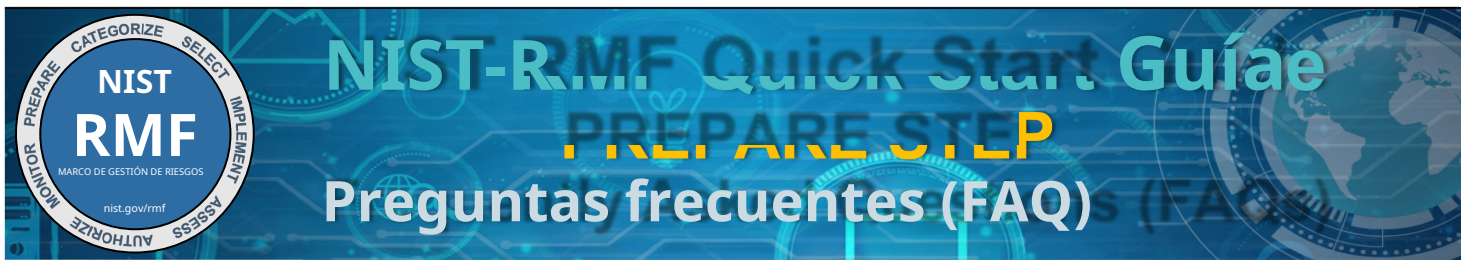
Preparar la Tarea P-4, *Líneas base de control adaptadas a la organización y perfiles del marco de ciberseguridad*, y Tarea P-6, *Priorización del nivel de impacto*, son opcionales. La Tarea P-4 a nivel organizacional es opcional porque las organizaciones determinan la aplicabilidad y la necesidad de conjuntos de controles especializados (por ejemplo, líneas base de control personalizadas) para uso en toda la organización. Las organizaciones pueden, a su discreción, utilizar el concepto de referencia de control personalizado cuando existe una divergencia de los supuestos fundamentales utilizados para crear las referencias de control iniciales en la Publicación especial 800-53B del NIST [\[SP 800-53B\]](#). Esto incluiría, por ejemplo, situaciones en las que la organización tiene riesgos específicos de seguridad y privacidad, una misión específica o necesidades comerciales, o planes para operar en entornos que no se abordan en las líneas de base iniciales. También se pueden desarrollar líneas de base de control adaptadas a la organización para agilizar el proceso de adaptación en toda la organización. Por ejemplo, una organización podría desarrollar una línea de base personalizada que se aplique a todas las aplicaciones de impacto moderado dentro de la organización. La Tarea P-6 a nivel organizacional es opcional porque las organizaciones pueden determinar que la granularidad adicional en sus designaciones de impacto facilita la toma de decisiones basada en el riesgo, incluida la asignación de recursos. Las organizaciones pueden usar la tarea de nivel organizacional P-6 para priorizar los sistemas dentro de cada nivel de impacto. Por ejemplo, *bajo-moderado* sistemas, *moderado-moderados* sistemas, y *alto-moderados* sistemas [\[Volver a la tabla de contenidos\]](#)

12. ¿Dónde encaja el paso Preparar en los pasos existentes del RMF?

El paso Preparar debe completarse antes de que se lleven a cabo los pasos o tareas restantes, ya que sus tareas respaldan las tareas posteriores. Las organizaciones que implementan el Marco de Gestión de Riesgos por primera vez normalmente llevan a cabo los pasos en orden secuencial, comenzando con el paso Preparar. Si el sistema ya se encuentra en la fase de operaciones y mantenimiento del ciclo de vida de desarrollo del sistema como parte del paso de monitoreo continuo, aún se deben realizar las tareas del paso Preparar para una gestión de riesgos efectiva. La idea es garantizar que las tareas del paso Preparar sean realizadas incluso por sistemas en operaciones. [\[Volver a la tabla de contenidos\]](#)

13. ¿Cuándo se consideran los requisitos de seguridad y privacidad dentro del ciclo de vida del desarrollo del sistema?

Todos los sistemas federales, incluidos los sistemas operativos, los sistemas en desarrollo y los sistemas en proceso de modificación o actualización, se encuentran en alguna fase del ciclo de vida del desarrollo del sistema. La definición de requisitos es una parte crítica de cualquier proceso de desarrollo de sistemas y comienza muy temprano en el ciclo de vida, generalmente en la fase de inicio. Los requisitos de seguridad y privacidad son un subconjunto de los requisitos funcionales y no funcionales generales impuestos a un sistema y se incorporan al ciclo de vida de desarrollo del sistema simultáneamente con los requisitos funcionales y no funcionales. Sin la integración temprana de los requisitos de seguridad y privacidad, la organización puede incurrir en gastos significativos más adelante en el ciclo de vida para abordar las consideraciones de seguridad y privacidad que podrían haberse incluido en el diseño inicial. Cuando los requisitos de seguridad y privacidad se consideran como un subconjunto integral de otros requisitos del sistema, el sistema resultante tiene menos debilidades y, por lo tanto, menos vulnerabilidades que pueden explotarse en el futuro. [\[Volver a la tabla de contenidos\]](#)



Preguntas frecuentes sobre los fundamentos de los pasos de preparación

14. ¿Qué es una estrategia de gestión de riesgos y por qué es necesaria?

La estrategia de gestión de riesgos guía e informa las decisiones basadas en riesgos, incluida la forma en que se enmarcan, evalúan, responden y monitorean los riesgos de seguridad y privacidad. La estrategia de gestión de riesgos hace explícitas las amenazas, los supuestos, las restricciones, las prioridades, las compensaciones y la tolerancia al riesgo que se utilizan para tomar decisiones operativas y de inversión. La estrategia incluye las decisiones y consideraciones de nivel estratégico sobre cómo los líderes y ejecutivos principales deben administrar la seguridad, la privacidad y los riesgos de la cadena de suministro para las operaciones y los activos de la organización, las personas, otras organizaciones y la Nación. La estrategia de gestión de riesgos incluye una expresión de tolerancia al riesgo organizacional; metodologías aceptables de evaluación de riesgos y estrategias de respuesta a los riesgos; un proceso para evaluar consistentemente la seguridad,¹ privacidad,² y cadena de suministro³ riesgos en toda la organización con respecto a la tolerancia al riesgo; y enfoques para monitorear el riesgo a lo largo del tiempo. La estrategia de gestión de riesgos de seguridad se aborda en NIST SP 800-39 [SP 800-39]. Los conceptos básicos de gestión de riesgos de privacidad y las consideraciones que pueden informar las estrategias de las organizaciones se proporcionan en NISTIR 8062 [IR 8062]. La estrategia de gestión de riesgos de la cadena de suministro se aborda en NIST SP 800-161 [SP 800-161]. [Volver a la tabla de contenidos]

15. ¿Qué es una evaluación de riesgos?

La evaluación del riesgo es uno de los cuatro componentes de la gestión de riesgos abordados en la estrategia de gestión de riesgos de la organización. Las evaluaciones de riesgo se utilizan para identificar, estimar y priorizar el riesgo para las operaciones de la organización (es decir, misión, funciones, imagen y reputación), los activos de la organización, las personas, otras organizaciones y la Nación, como resultado de la operación y el uso de los sistemas. El propósito de las evaluaciones de riesgos de seguridad es informar a los tomadores de decisiones y respaldar las respuestas a los riesgos mediante la identificación de (i) amenazas relevantes para las organizaciones o amenazas dirigidas a través de organizaciones contra otras organizaciones; (ii) vulnerabilidades, tanto internas como externas a las organizaciones; (iii) impacto (es decir, daño) a las organizaciones que puede ocurrir dado el potencial de amenazas que explotan vulnerabilidades; y (iv) la probabilidad de que ocurra un daño. El resultado final es una determinación del riesgo (es decir, típicamente una función del grado de daño y la probabilidad de que ocurra el daño). NIST SP 800-30 [SP 800-30] proporciona orientación sobre la realización de evaluaciones de riesgos. Las evaluaciones de riesgo de privacidad se llevan a cabo para determinar la probabilidad de que una determinada operación que realiza el sistema al procesar PII pueda tener un efecto adverso en las personas y el impacto potencial en esas personas. NISTIR 8062 [IR 8062] presenta la gestión de riesgos de privacidad y un modelo de riesgo de privacidad para las evaluaciones de riesgos de privacidad. Las organizaciones pueden utilizar la herramienta Metodología de evaluación de riesgos de privacidad (PRAM) del NIST para aplicar el modelo de riesgo de NISTIR 8062 y analizar, evaluar y priorizar los riesgos de privacidad. [Volver a la tabla de contenidos]

16. ¿Qué es un perfil de Cybersecurity Framework o Privacy Framework?

Un perfil es una selección de resultados del Marco de seguridad cibernética o Marco de privacidad básico basado en la misión y las funciones comerciales, los requisitos de seguridad y privacidad y las determinaciones de riesgo. Muchas de las tareas en el paso de preparación organizacional brindan una vista a nivel de la organización de estas consideraciones (es decir, funciones, requisitos de seguridad y privacidad y determinaciones de riesgos) y pueden servir como entradas para un perfil. La lista priorizada resultante de resultados de seguridad cibernética y privacidad desarrollada a nivel de organización y misión y proceso comercial puede ser útil para facilitar decisiones coherentes basadas en riesgos a nivel de sistema durante la ejecución de los pasos de RMF. Los perfiles también se pueden usar para guiar e informar el desarrollo de las líneas base de control personalizadas descritas en NIST SP 800-37 [SP 800-37r2] y NIST SP 800-53B [SP 800-53B]. Para obtener más información sobre el marco de ciberseguridad, consulte [LCR del NIST]. Para obtener más información sobre el marco de privacidad, consulte [PF del NIST]. [Volver a la tabla de contenidos]

¹La estrategia de gestión de riesgos de seguridad se aborda en NIST SP 800-39 [SP 800-39].

²La estrategia de gestión de riesgos de privacidad se aborda en NISTIR 8062 [IR 8062].

³La estrategia de gestión de riesgos de la cadena de suministro se aborda en NIST SP 800-161 [SP 800-161].



17. ¿Qué es un control común?

Control Son garantías para proteger *el seguridad* de la información y los sistemas, así como la *privacidad* de individuos. Los controles comunes son controles proporcionados por una entidad del sistema o no del sistema distinta del sistema de interés que puede ser heredado por uno o más sistemas organizacionales. Los controles comunes promueven una seguridad de la información más rentable y uniforme en toda la organización y también pueden simplificar las actividades de gestión de riesgos. Estos controles pueden incluir, por ejemplo, controles de protección física y ambiental, protección de límites y controles de monitoreo, controles de seguridad del personal, políticas y procedimientos, controles de adquisición, controles de gestión de cuentas e identidad, registros de auditoría y controles de responsabilidad, o controles de gestión de quejas para recibir privacidad. consultas relacionadas con el público.

Desde el punto de vista del sistema, heredar controles comunes puede generar menos controles para implementar (y mantener) y, por lo tanto, menos gastos. Sin embargo, muchos controles comunes son en realidad controles híbridos en los que la organización o el sistema que ofrece los controles solo proporciona una parte de los controles. El sistema es entonces responsable de implementar la parte restante de los controles comunes. Tomemos, por ejemplo, el CONTROL DE ACCESO FÍSICO PE-3. Un sistema puede ser un inquilino dentro de una instalación administrada y operada por una organización separada responsable de la instalación, incluido el control del acceso a la instalación, pero el sistema aún puede ser responsable de los elementos de control restantes que no ofrece el proveedor de control común.

Las organizaciones o entidades que ofrecen controles comunes para la herencia deben asegurarse de que los detalles de implementación del control se comuniquen a los sistemas heredados y que se proporcione cualquier guía adicional para la implementación (p. ej., en el caso de controles híbridos). Tal orientación es beneficiosa para los sistemas heredados así como para los asesores de control. Cualquier cambio en las ofertas de control, incluida la forma en que se implementan los controles comunes, también debe comunicarse. Ya sea que los proveedores de control comunes ofrezcan controles para toda la organización o para sistemas específicos, es responsabilidad e interés del sistema heredero asegurarse de que esté informado de cualquier cambio en las ofertas de control. Puede haber casos en los que las organizaciones publiquen información sobre cambios en sus ofertas de control común, y depende de los sistemas heredados responder a dichos cambios.

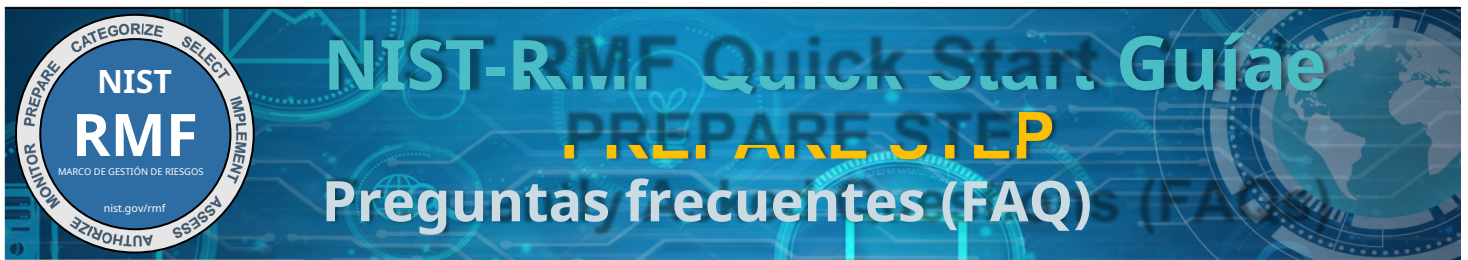
Para una discusión adicional sobre los controles comunes, consulte Preparación de RMF: paso de nivel de organización, tarea P-5, *Identificación de control común* NIST SP 800-53 [SP 800-53r5]. [[Volver a la tabla de contenidos](#)]

18. ¿Cómo se determinan los controles comunes para la organización?

El proceso de toda la organización para determinar los controles comunes incluye consideraciones de las categorías de seguridad y los niveles de impacto de los sistemas dentro de la organización; requisitos legislativos, reglamentarios o de políticas; y los controles necesarios para mitigar adecuadamente los riesgos de seguridad y privacidad que se derivan del uso de dichos sistemas. Cuando los controles comunes protegen múltiples sistemas organizacionales de diferentes niveles de impacto, los controles se implementan con respecto al nivel de impacto más alto entre los sistemas. La asignación de requisitos de seguridad y privacidad al sistema y al entorno en el que opera determina qué controles de seguridad y privacidad se designan como controles comunes. [[Volver a la tabla de contenidos](#)]

19. ¿Quién debe definir los controles comunes?

La identificación de controles comunes se logra de manera más efectiva como un ejercicio de toda la organización con la participación activa del oficial superior de seguridad de la información de la agencia, el oficial superior de la agencia para la privacidad, el propietario de la misión o el negocio, el oficial superior responsable de la gestión de riesgos o el ejecutivo de riesgos (función), director de información, oficial de autorización o representante designado del oficial de autorización, proveedor de control común y propietario del sistema. [[Volver a la tabla de contenidos](#)]



20. ¿Qué es una arquitectura empresarial?

Arquitectura empresarial es una práctica de gestión utilizada por las organizaciones para maximizar la eficacia de la misión y los procesos comerciales y los recursos de información y para lograr el éxito de la misión y el negocio. Una arquitectura empresarial puede ayudar a proporcionar una mayor comprensión de las tecnologías operativas y de la información incluidas en el diseño y desarrollo iniciales de los sistemas y debe considerarse un requisito previo para lograr la resiliencia y la capacidad de supervivencia de esos sistemas frente a amenazas cada vez más sofisticadas, así como para proteger la privacidad de las personas frente a un procesamiento de datos cada vez más complejo. La arquitectura empresarial brinda una oportunidad para que las organizaciones consoliden, estandaricen y optimicen los activos de información y tecnología. Una arquitectura empresarial implementada efectivamente produce sistemas que son más transparentes y, por lo tanto, más fácil de entender y proteger. La arquitectura empresarial también establece una conexión clara e inequívoca entre las inversiones y las mejoras de rendimiento medibles. [\[Volver a la tabla de contenidos\]](#)

21. ¿Cuál es la diferencia entre los requisitos de seguridad y privacidad y los controles de seguridad y privacidad?

El término seguridad y privacidad *requisitos* es utilizado por diferentes comunidades y grupos de diferentes maneras y puede requerir una explicación adicional para establecer los contextos particulares para los diversos casos de uso. Los requisitos de seguridad y privacidad se pueden establecer en un nivel muy alto de abstracción, como en la legislación, órdenes ejecutivas, directivas, políticas, estándares y declaraciones de misión y necesidades comerciales. FISMA y FIPS Publicación 200 [\[FIP 200\]](#) articular requisitos a tal nivel.

El personal de adquisiciones desarrolla requisitos de seguridad y privacidad para fines de contratación que abordan las protecciones necesarias para lograr la misión y las necesidades comerciales. Los ingenieros de sistemas/seguridad, los desarrolladores de sistemas y los integradores de sistemas desarrollan los requisitos de diseño de seguridad para el sistema, desarrollan la arquitectura del sistema y los requisitos de seguridad y privacidad derivados específicos de la arquitectura y, posteriormente, implementan funciones de seguridad específicas en el componente de hardware, software y firmware. nivel.

Los requisitos de seguridad y privacidad también se reflejan en varios controles de seguridad y privacidad no técnicos que abordan cuestiones tales como políticas y procedimientos para la gestión y los elementos operativos dentro de las organizaciones, nuevamente en diferentes niveles de detalle. Es importante definir el contexto para cada uso del término requisito de seguridad y privacidad para que las respectivas comunidades (incluidas las personas responsables de la política, la arquitectura, la adquisición, la ingeniería y la protección de la misión y el negocio) puedan comunicar claramente su intención.

Los controles son salvaguardias: mecanismos de protección destinados a cumplir los requisitos, ya sean requisitos de seguridad o requisitos de privacidad. Es importante que los controles se implementen correctamente y funcionen según lo previsto para garantizar que los requisitos se cumplan continuamente. La evaluación de los controles es un método para verificar que se cumplen los requisitos. [\[Volver a la tabla de contenidos\]](#)

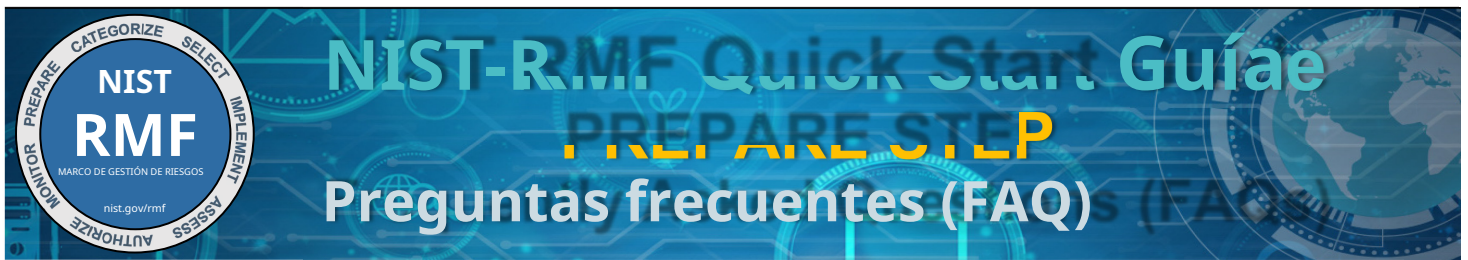
22. ¿Qué es un límite de autorización?

Los límites de autorización establecen el alcance de los sistemas que se protegerán, administrarán y autorizarán para su operación o uso. Los límites de autorización se determinan mediante la autorización de funcionarios con aportes del propietario del sistema en función de la misión, la gestión o la responsabilidad presupuestaria. Nótese que el término *límite del sistema* no se usa en NIST SP 800-37, Revisión 2 [\[SP 800-37r2\]](#). [\[Volver a la tabla de contenidos\]](#)

23. ¿Es el límite de la autorización lo mismo que el límite del sistema?

Históricamente, NIST ha utilizado los términos *límite de autorización* y *límite del sistema* indistintamente. En aras de la claridad, la precisión y el uso de terminología estandarizada, el término *límite de autorización* ahora se usa exclusivamente para referirse al conjunto de sistema

«El proceso de Arquitectura Empresarial Federal es administrado por la Oficina de Gerencia y Presupuesto. [\[OMB FEA\]](#)



elementos que componen el sistema que se autorizará para su funcionamiento o para su uso por parte de un funcionario autorizador (es decir, el alcance de la autorización). El límite de autorización también puede referirse a un conjunto de controles comunes que se autorizarán con fines de herencia. [\[Volver a la tabla de contenidos\]](#)

24. ¿Cuándo se debe establecer el límite de autorización?

El límite de autorización se establece en la Tarea P-11, *Límite de autorización*, del paso Preparar – Nivel del sistema (muy temprano en el ciclo de vida de desarrollo del sistema). El límite de autorización se establece después de determinar la misión y los procesos comerciales que respaldará el sistema e identificar a las partes interesadas del sistema y el conjunto de activos que requieren protección, pero antes de identificar los tipos de información que el sistema procesará, almacenará o transmitirá. realizar una evaluación de riesgos. Las tareas en el paso RMF Categorize y todos los pasos/tareas subsiguientes de RMF no se pueden realizar de manera efectiva sin un límite de autorización establecido.

[\[Volver a la tabla de contenidos\]](#)

25. ¿Quién es responsable de establecer el límite de autorización?

El funcionario autorizador tiene la responsabilidad principal de establecer el límite de autorización con el director de información, el propietario del sistema, el propietario de la misión o el negocio, el oficial superior de seguridad de la información de la agencia, el oficial superior de privacidad de la agencia y el arquitecto empresarial que desempeña funciones de apoyo. El proceso de establecer límites para los sistemas de la organización y determinar las implicaciones de autorización de seguridad asociadas de esos límites es una actividad organizacional que debe incluir una negociación cuidadosa entre todos los participantes clave. Una vez que se establece el límite de autorización, el propietario de la información/propietario del sistema y el oficial de seguridad del sistema de apoyo son responsables de la adquisición, el desarrollo, la integración, la modificación, la operación y el mantenimiento generales del sistema. [\[Volver a la tabla de contenidos\]](#)

26. ¿Cómo se establece el límite de autorización?

El establecimiento de límites para los sistemas de una organización debe tener en cuenta la misión o los requisitos comerciales de la organización, las consideraciones técnicas con respecto a la seguridad y privacidad de la información, los costos programáticos para la organización y los efectos de los límites en la autorización de los sistemas de la organización. Para identificar el límite de autorización, el propietario de la información/propietario del sistema debe determinar si los recursos de información:

- Están bajo el mismo control directo de gestión;
- Tener la misma función, objetivo de la misión, características de funcionamiento y necesidades de seguridad y privacidad;
- Procesar, almacenar y transmitir tipos similares de información (por ejemplo, categorizados en el mismo nivel de impacto); o
- Residir en el mismo entorno operativo general (o, en el caso de un sistema distribuido, residir en varias ubicaciones con entornos operativos similares).

Los límites que son innecesariamente extensos (es decir, incluyen demasiados componentes del sistema) hacen que el sistema sea difícil de administrar y que el proceso de autorización sea difícil de manejar y complejo. Los límites que se limitan innecesariamente aumentan el número de autorizaciones que se deben realizar e inflan los costos totales para la organización. Para los sistemas que procesan PII, los programas de privacidad y seguridad pueden colaborar para desarrollar una comprensión común de los límites de autorización porque los riesgos de privacidad pueden surgir del procesamiento de datos que ocurre más allá de lo que los programas de seguridad normalmente considerarían el límite de autorización.

Las categorías de seguridad pueden desempeñar un papel importante en la definición de los límites de autorización apropiados al dividir los sistemas según los niveles de impacto y la importancia de esos sistemas para llevar a cabo la misión y los procesos comerciales de la organización. El proceso de partición facilita la aplicación rentable de controles para lograr una seguridad adecuada acorde con los posibles impactos adversos que pueden surgir a través de los respectivos sistemas. Los mapas de datos creados bajo la Tarea P-13 también ayudan a las organizaciones a comprender dónde se está procesando la información y cómo puede afectar los riesgos de privacidad que surgen en los sistemas para facilitar la aplicación de los controles apropiados. [\[Volver a la tabla de contenidos\]](#)



NIST-RMF Quick Start Guía

PREPARE STEP

Preguntas frecuentes (FAQ)

27. ¿Cuáles son los diversos tipos de información que procesan los sistemas gubernamentales?

Los sistemas suelen procesar varios tipos de información. NIST SP 800-60 [SP 800-60v1] divide la información en dos categorías principales: información asociada con las actividades específicas de la misión de una organización e información asociada con las actividades administrativas, de gestión y de apoyo comunes a la mayoría de las organizaciones. Las áreas comerciales que separan las operaciones gubernamentales en categorías de alto nivel se pueden desglosar de la siguiente manera:

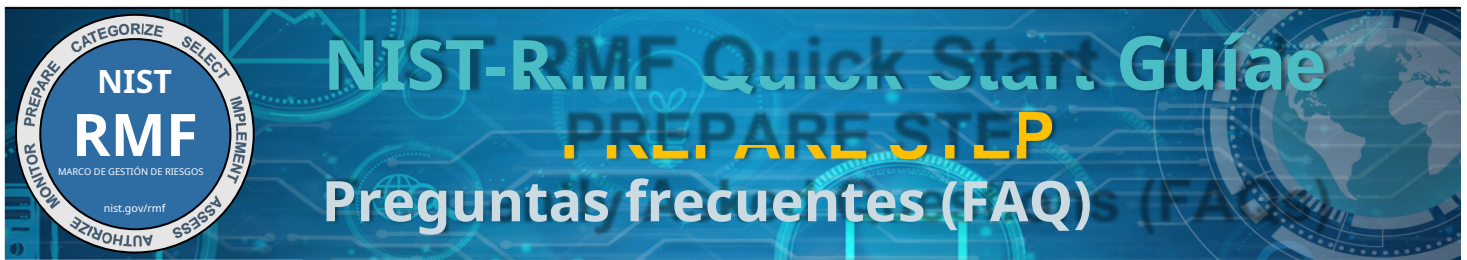
- Tipos de información basada en misiones:
 - Propósito del gobierno (*servicios para los ciudadanos*)
 - Mecanismos que utiliza el gobierno para lograr su propósito (*Modo de entrega*)
- Tipos de información de gestión y soporte:
 - Funciones de apoyo necesarias para llevar a cabo operaciones gubernamentales (*apoyar la entrega de servicios*)
 - Funciones de gestión de recursos que respaldan todas las áreas del negocio del gobierno (*manejo de los recursos del gobierno*)

Los tipos de información basados en misiones son, por definición, específicos de organizaciones individuales o grupos de organizaciones, y son la fuente principal para determinar los riesgos de privacidad, los valores de impacto en la seguridad y los objetivos de seguridad e ingeniería de privacidad para la información y los sistemas basados en misiones. Las consecuencias o impactos de la divulgación no autorizada de información, la violación de la integridad y la denegación de servicios se definen por la naturaleza de las dos áreas comerciales asociadas con los tipos de información basada en la misión, que incluyen lo siguiente:

- El propósito del gobierno (*servicios para los ciudadanos*) El área comercial describe la misión y el propósito del gobierno de los Estados Unidos en términos de los servicios que brinda a los ciudadanos estadounidenses y en su nombre. Comprende la entrega de bienes y prestaciones como servicio, públicos y colectivos, enfocados al ciudadano, así como las obligaciones del Gobierno Federal en beneficio y protección de la población en general de la Nación. Un ejemplo de *servicios para los ciudadanos* El área comercial es la línea comercial de gestión de desastres que involucra las actividades necesarias para prepararse, mitigar, responder y reparar los efectos de todos los desastres, ya sean naturales o provocados por el hombre. La línea de negocios de gestión de desastres incluye cuatro tipos de información: 1) monitoreo y predicción de desastres, 2) preparación y planificación de desastres, 3) reparación y restauración de desastres, y 4) respuesta de emergencia.
- Los mecanismos que utiliza el Gobierno para lograr su propósito (*Modo de entrega*) El área de negocio describe los mecanismos que utiliza el Gobierno para prestar sus servicios a los ciudadanos. Un ejemplo de *Modo de entrega* El área de negocios es la línea de negocios de asistencia financiera federal que brinda beneficios financieros o monetarios ganados y no ganados a individuos, grupos o corporaciones. Hay cuatro tipos de información asociados con la línea de negocios de asistencia financiera federal: 1) subvenciones federales, 2) transferencias directas a individuos, 3) subsidios y 4) créditos fiscales.

Gran parte de la información y los sistemas de apoyo de una organización no se utilizan para prestar servicios directos basados en la misión, sino principalmente para apoyar la prestación de servicios y gestionar los recursos. Las dos áreas comerciales asociadas con los tipos de información de administración y soporte incluyen lo siguiente:

- Las funciones de apoyo necesarias para llevar a cabo las operaciones gubernamentales (*apoyar la entrega de servicios*) proporciona la base política, programática y administrativa crítica para respaldar las operaciones del gobierno federal. Un ejemplo de *apoyar la entrega de servicios* El área comercial es la línea comercial de desarrollo regulatorio que involucra actividades asociadas con el desarrollo de regulaciones, políticas y orientación para implementar leyes. La línea de negocios de desarrollo regulatorio incluye cuatro tipos de información: 1) desarrollo de políticas y guías, 2) seguimiento de comentarios públicos, 3) creación regulatoria y 4) publicación de reglas.
- Las funciones de gestión de recursos que apoyan todas las áreas de negocio del Gobierno (*manejo de los recursos del gobierno*) área de negocio se refiere a las actividades de apoyo que permiten al Gobierno operar de manera eficiente. Un ejemplo de *manejo de los recursos del gobierno* El área de negocios es la línea de negocios de gestión de recursos humanos que involucra todas las actividades asociadas con el reclutamiento y la gestión de personal. La línea de negocio de gestión de recursos humanos



incluye diez tipos de información: 1) estrategia de recursos humanos, 2) adquisición de personal, 3) organización y gestión de puestos, 4) gestión de compensaciones, 5) gestión de beneficios, 6) gestión del desempeño de los empleados, 7) relaciones con los empleados, 8) relaciones laborales, 9) gestión de separaciones, y 10) desarrollo de recursos humanos.

Cada sistema puede procesar información que no encaja claramente en uno de los tipos de información incluidos en NIST SP 800-60, Volumen II [\[SP 800-60v2\]](#). Una vez que se ha identificado un conjunto de tipos de información para un sistema, es prudente revisar la información real procesada, almacenada o transmitida para determinar si es necesario identificar tipos adicionales de información con fines de evaluación del impacto en la seguridad y la privacidad. [\[Volver a la tabla de contenidos\]](#)

Asistencia organizativa para las preguntas frecuentes sobre el paso de preparación

28. ¿Cómo establecen las organizaciones tipos de información basados en misiones?

El enfoque para establecer tipos de información basados en la misión comienza documentando la misión y las áreas comerciales de la organización. En el caso de la información basada en la misión, la oficina del programa de seguridad de la información, en coordinación con la gerencia, el personal de operaciones técnicas, la arquitectura empresarial y otras partes interesadas, compila un conjunto integral de las áreas de misión, las líneas de negocios y las subfunciones aplicables de la organización, relacionados con las líneas de misión y áreas de negocio. Por ejemplo, la misión de una organización podría estar relacionada con el desarrollo económico. Las subfunciones que forman parte de la misión de desarrollo económico de la organización pueden incluir el desarrollo comercial e industrial, la protección de la propiedad intelectual o la supervisión del sector financiero. Cada una de estas subfunciones representa un tipo de información.

Cuando un tipo de información organizacional no está categorizado en NIST SP 800-60 [\[SP 800-60v2\]](#), las personas responsables dentro de la organización deben realizar una determinación de impacto inicial basada en la publicación 199 de FIPS [\[FIP 199\]](#) criterios de categorización definidos en la Tabla 1, *Definiciones de impacto potencial para los objetivos de seguridad*. Para cada tipo de información, a cada objetivo de seguridad (confidencialidad, integridad y disponibilidad) se le asigna un valor de impacto (bajo, moderado o alto) seleccionando y ajustando los valores apropiados de la Tabla 1 de la Publicación 199 de FIPS.

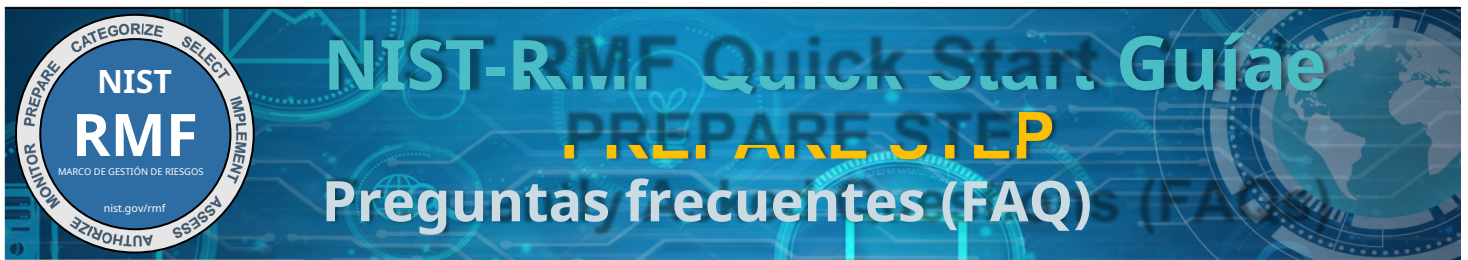
Una vez que los tipos de información de la organización han sido identificados, validados como consistentes con la arquitectura empresarial de la organización y documentados, la oficina del programa de seguridad de la información prepara un suplemento para NIST SP 800-60 [\[SP 800-60v2\]](#) de tipos de información adicionales específicos de la organización, los valores de impacto recomendados para cada objetivo de seguridad (confidencialidad, integridad y disponibilidad), la justificación de cada valor de impacto elegido y los factores especiales que afectan la determinación del impacto para cada información específica de la organización. tipo. El suplemento de la organización a NIST SP 800-60 se distribuye al propietario de la información/propietarios del sistema para que lo utilicen al categorizar sus sistemas individuales. [\[Volver a la tabla de contenidos\]](#)

29. ¿Cuáles son las funciones y responsabilidades clave de la organización en el paso Preparar?

Referirse a *Cruce de roles y responsabilidades de RMF* tabla de funciones y responsabilidades clave de la organización. [\[Volver a la tabla de contenidos\]](#)

30. ¿Qué es una línea de base de control adaptada a la organización?

Una línea de base de control adaptada a la organización se aplica a dos o más sistemas organizacionales y proporciona un conjunto completamente especificado de controles, mejoras de control y orientación complementaria derivada de las líneas de base de control establecidas descritas en NIST SP 800-53B [\[SP 800-53B\]](#). Las líneas base adaptadas a la organización complementan las líneas base de control inicial agregando o eliminando controles, especificando controles de compensación, especificando requisitos de implementación y estableciendo valores de parámetros para declaraciones de asignación o selección en controles y mejoras de control que son aceptables para las comunidades de interés de la organización. Las líneas de base adaptadas a la organización también pueden ampliar la orientación complementaria cuando sea necesario. [\[Volver a la tabla de contenidos\]](#)



31. ¿Cuál es el origen de las nuevas tareas en el paso Preparar - Nivel organizacional?

Las tareas del paso de preparación se derivan de la política de la OMB (p. ej., OMB Circular A-130 [\[OGP A130\]](#)) y de varias publicaciones relacionadas con la gestión de riesgos del NIST (p. ej., publicación 199 de FIPS [\[FIP 199\]](#), NIST SP 800-30 [\[SP 800-30\]](#), NIST SP 800-39 [\[SP 800-39\]](#), NIST SP 800-53 [\[SP 800-53\]](#), NIST SP 800-60 [\[SP 800-60v1\]](#) y [\[SP 800-60v2\]](#), NIST SP 800-137 [\[SP 800-137\]](#), NIST SP 800-160 [\[SP 800-160\]](#), NIST SP 800-161 [\[SP 800-161\]](#) y NIST IR 8062 [\[IR 8062\]](#)). [\[Volver a la tabla de contenidos\]](#)

Preguntas frecuentes sobre la aplicación específica del sistema del paso de preparación

32. ¿Por qué se agregó la tarea de límite de autorización?

La tarea de límite de autorización se agregó porque no existía una tarea específica para determinar el límite de autorización en la versión anterior del marco de gestión de riesgos. La determinación del límite de autorización establece el alcance de la protección de un sistema; el propietario de un sistema no puede determinar los recursos de información necesarios sin una delimitación clara del límite de autorización. La delimitación clara de los límites de autorización es importante para la rendición de cuentas, las evaluaciones de impacto en la privacidad y la categorización de la seguridad, especialmente en situaciones en las que los sistemas de menor impacto están conectados a sistemas de mayor impacto. Además, las tareas en el paso Categorizar y todos los pasos/tareas posteriores de RMF no se pueden realizar de manera efectiva sin un límite de autorización establecido.

[\[Volver a la tabla de contenidos\]](#)

33. ¿Qué es el ciclo de vida de la información?

El ciclo de vida de la información de identificación personal (PII) incluye la creación, la recopilación, el uso, el procesamiento, el almacenamiento, la difusión, el mantenimiento, la divulgación o la eliminación (es decir, el "procesamiento" colectivo) de la PII. Un sistema puede necesitar procesar PII en su totalidad o en parte de su ciclo de vida para lograr la misión o las funciones comerciales de la organización. Identificar y comprender todas las partes del ciclo de vida de la información ayuda a informar la evaluación de riesgos de privacidad de la organización y la posterior selección e implementación de controles. [\[Volver a la tabla de contenidos\]](#)

34. ¿Qué es el registro del sistema?

El registro del sistema, de acuerdo con la política de la organización, sirve para informar a la organización rectora de los planes para desarrollar el sistema o la existencia del sistema, las características clave del sistema y las implicaciones esperadas de seguridad y privacidad para la organización debido al uso continuo y funcionamiento del sistema. En NIST SP 800-37, Revisión 1 [\[SP 800-37r1\]](#), el registro del sistema era una tarea en el paso Categorizar. Se movió al paso Preparar porque proporciona a las organizaciones una herramienta de gestión/seguimiento efectiva al principio del ciclo de vida de desarrollo del sistema para facilitar la incorporación del sistema a la arquitectura, la implementación de protecciones que son acordes con el riesgo y la postura de seguridad y privacidad. informes [\[Volver a la tabla de contenidos\]](#)

35. ¿Cuál es el origen de las nuevas tareas en el paso Preparar - Nivel del sistema?

Las tareas del paso de preparación se derivan de la política de la OMB (p. ej., OMB Circular A-130 [\[OGP A130\]](#)) y varias publicaciones relacionadas con la gestión de riesgos del NIST (p. ej., publicación 199 de FIPS [\[FIP 199\]](#), NIST SP 800-30 [\[SP 800-30\]](#), NIST SP 800-39 [\[SP 800-39\]](#), NIST SP 800-53 [\[SP 800-53\]](#), NIST SP 800-60 [\[SP 800-60v1\]](#) y [\[SP 800-60v2\]](#), NIST SP 800-137 [\[SP 800-137\]](#), NIST SP 800-160 [\[SP 800-160\]](#), NIST SP 800-161 [\[SP 800-161\]](#) y NIST IR 8062 [\[IR 8062\]](#)). [\[Volver a la tabla de contenidos\]](#)



Referencias

- [FIP 199] Instituto Nacional de Estándares y Tecnología (2004) Estándares para la Categorización de Seguridad de Información Federal y Sistemas de Información. (Departamento de Comercio de EE. UU., Washington, DC), Publicación Federal de Estándares de Procesamiento de la Información (FIPS) 199. <https://doi.org/10.6028/NIST.FIPS.199>
- [FIP 200] Instituto Nacional de Estándares y Tecnología (2006) Requisitos mínimos de seguridad para información federal y sistemas de información. (Departamento de Comercio de EE. UU., Washington, DC), Publicación de Normas Federales de Procesamiento de la Información (FIPS) 200. <https://doi.org/10.6028/NIST.FIPS.200>
- [IR 8062] Brooks SW, Garcia ME, Lefkovitz NB, Lightman S, Nadeau EM (2017) Introducción a la ingeniería de privacidad y gestión de riesgos en sistemas federales. (Instituto Nacional de Estándares y Tecnología, Gaithersburg, MD), NIST Interagency or Internal Report (IR) 8062. <https://doi.org/10.6028/NIST.IR.8062>
- [LCR del NIST] Instituto Nacional de Normas y Tecnología *Marco para mejorar la ciberseguridad de la infraestructura crítica* (Marco de ciberseguridad), Versión 1.1, abril de 2018. <https://www.nist.gov/cyberframework>
- [NIST PF] Instituto Nacional de Estándares y Tecnología (2020) Marco de privacidad del NIST: una herramienta para mejorar la privacidad a través de la gestión de riesgos empresariales, versión 1.0 (Instituto Nacional de Estándares y Tecnología, Gaithersburg, MD). Disponible en: <https://doi.org/10.6028/NIST.CSWP.01162020>
- [OGP A130] Oficina de Gerencia y Presupuesto (2016) *Gestión de la información como recurso estratégico*. (La Casa Blanca, Washington, DC), OMB Circular A-130, 28 de julio de 2016. Disponible en <https://www.whitehouse.gov/sites/whitehouse.gov/files/omb/circulars/A130/a130revised.pdf>
- [COCHECITO] Metodología de evaluación de riesgos de privacidad (PRAM) del NIST <https://www.nist.gov/itl/applied-cybersecurity/privacy-engineering/resources>
- [ES 800-30] Iniciativa de Transformación de la Fuerza de Tarea Conjunta (2012) Guía para realizar evaluaciones de riesgos. (Instituto Nacional de Estándares y Tecnología, Gaithersburg, MD), Publicación Especial NIST (SP) 800-30, Rev. 1. <https://doi.org/10.6028/NIST.SP.800-30r1>
- [ES 800-37r1] Joint Task Force (2010) Guía para aplicar el marco de gestión de riesgos a los sistemas de información federales: un enfoque del ciclo de vida de la seguridad. (Instituto Nacional de Estándares y Tecnología, Gaithersburg, MD), Publicación Especial NIST (SP) 800-37, Rev. 1 [retirado]. <https://doi.org/10.6028/NIST.SP.800-37r1>
- [ES 800-37r2] Grupo de trabajo conjunto (2018) Marco de gestión de riesgos para sistemas y organizaciones de información: un enfoque del ciclo de vida del sistema para la seguridad y la privacidad. (Instituto Nacional de Estándares y Tecnología, Gaithersburg, MD), Publicación Especial NIST (SP) 800-37, Rev. 2. <https://doi.org/10.6028/NIST.SP.800-37r2>
- [ES 800-39] Iniciativa de transformación del grupo de trabajo conjunto (2011) Gestión del riesgo de seguridad de la información: vista de la organización, la misión y el sistema de información. (Instituto Nacional de Estándares y Tecnología, Gaithersburg, MD), Publicación Especial NIST (SP) 800-39. <https://doi.org/10.6028/NIST.SP.800-39>
- [ES 800-53r5] Fuerza de Tarea Conjunta (2020) Controles de seguridad y privacidad para sistemas y organizaciones de información. (Instituto Nacional de Estándares y Tecnología, Gaithersburg, MD), Publicación Especial NIST (SP) 800-53, Rev. 5. <https://doi.org/10.6028/NIST.SP.800-53r5>



- [ES 800-53B] Joint Task Force (2020) Control Baselines for Information Systems and Organisations. (Instituto Nacional de Estándares y Tecnología, Gaithersburg, MD), Publicación Especial NIST (SP) 800-53B. <https://doi.org/10.6028/NIST.SP.800-53B>
- [ES 800-60v1] Stine KM, Kissel RL, Barker WC, Fahlsing J, Gulick J (2008) Guía para la asignación de tipos de información y sistemas de información a categorías de seguridad. (Instituto Nacional de Estándares y Tecnología, Gaithersburg, MD), Publicación Especial NIST (SP) 800-60, vol. 1, rev. 1. <https://doi.org/10.6028/NIST.SP.800-60v1r1>
- [ES 800-60v2] Stine KM, Kissel RL, Barker WC, Lee A, Fahlsing J (2008) Guía para la asignación de tipos de información y sistemas de información a categorías de seguridad: Apéndices. (Instituto Nacional de Estándares y Tecnología, Gaithersburg, MD), Publicación Especial NIST (SP) 800-60, vol. 2, rev. 1. <https://doi.org/10.6028/NIST.SP.800-60v2r1>
- [ES 800-137] Dempsey KL, Chawla NS, Johnson LA, Johnston R, Jones AC, Orebaugh AD, Scholl MA, Stine KM (2011) Monitoreo continuo de seguridad de la información (ISCM) para organizaciones y sistemas de información federales. (Instituto Nacional de Estándares y Tecnología, Gaithersburg, MD), Publicación Especial NIST (SP) 800-137. <https://doi.org/10.6028/NIST.SP.800-137>
- [ES 800-160v1] Ross RS, Oren JC, McEvilly M (2016) Ingeniería de seguridad de sistemas: consideraciones para un enfoque multidisciplinario en la ingeniería de sistemas seguros confiables. (Instituto Nacional de Estándares y Tecnología, Gaithersburg, MD), Publicación Especial NIST (SP) 800-160, vol. 1, Incluye actualizaciones al 21 de marzo de 2018. <https://doi.org/10.6028/NIST.SP.800-160v1>
- [ES 800-161] Boyens JM, Paulsen C, Moorthy R, Bartol N (2015) Prácticas de gestión de riesgos de la cadena de suministro para organizaciones y sistemas de información federales. (Instituto Nacional de Estándares y Tecnología, Gaithersburg, MD), Publicación Especial NIST (SP) 800-161. <https://doi.org/10.6028/NIST.SP.800-161>

[\[Volver a la tabla de contenidos\]](#)